

BGIN Meeting Report

Date: TBD

Location: Virtual Meeting

Executive Summary

The meeting focused on advancing key management practices, particularly in the context of exchanges and their operational challenges across different jurisdictions. Key topics included the standardization of terminology to ensure clarity among policymakers and market participants, as well as an in-depth discussion on security considerations for both HSM (Hardware Security Module) and non-HSM environments. Participants emphasized the importance of robust physical security measures, such as secure rooms for key ceremonies, regular key rotations, and backups. The human factor was also highlighted, with a focus on mitigating vulnerabilities associated with executives having access to key material.

The conversation then shifted to governance and compliance issues, including best practices for handling key transfers during mergers and acquisitions and the role of third-party management in securing transactions. There was a strong call for standards bodies like ISO and IEEE to align their guidelines with industry practices. The session concluded with a consensus on the need to develop a taxonomy and lifecycle framework for key management practices, along with a call for contributors to focus on practical use cases that have real-world impact. The meeting set clear next steps and reminded participants about the break before the subsequent session.

Key Discussion Points

Summary

1. Standardization of Terminology: - **Importance:** Clear definitions are crucial to avoid confusion among policymakers and market participants. - **Challenges:** Different jurisdictions often invent their own language, leading to inconsistencies. - **Solution:** Develop a subset of definitions that can be aligned with other standards bodies like ISO and IEEE.

2. Key Management Practices: - **HSM vs. Non-HSM Environments:** Both have unique security considerations, including physical security measures and regular key rotations. - **Human Factors:** The risk of executives having access to key material and the need for clear governance provisions during mergers and acquisitions. - **Third-**

Party Management: Ensuring the integrity of transactions by managing addresses and transaction content.

3. Governance and Compliance: - **Key Transfers:** Clear processes are needed for transferring keys, especially in sensitive scenarios like M&A. - **Regulatory Red Flags:** Identifying and addressing red flags such as founders having access to key material. - **Third-Party Management:** Ensuring the security of transactions through third-party management and alignment with regulatory standards.

4. Practical Use Cases: - **Focus on Impactful Scenarios:** Prioritize use cases that have a significant impact in the industry, rather than exotic or niche scenarios. - **Collaboration:** Leverage the strengths and resources of Begin and its partners to influence standards and policy discourse.

Action Items and Next Steps

1. **Develop Taxonomy:**
 - Create a subset of definitions for key management practices.
 - Align these definitions with other standards bodies like ISO and IEEE.
2. **Create Lifecycle Framework:**
 - Develop a lifecycle framework for key management, including pros and cons, additional controls, and governance considerations.
3. **Focus on Practical Use Cases:**
 - Identify and document use cases that have real-world impact in the industry.
 - Ensure these use cases are not exotic or niche scenarios.
4. **Collaborate with Partners:**
 - Engage with Begin's partners to gather input and collaborate on the development of standards and guidelines.
 - Leverage the strengths and resources of these partners to influence policy discourse.

Participants' Contributions

- **Participant A:** Emphasized the importance of standardizing terminology and aligning definitions with other standards bodies.
- **Participant B:** Highlighted the need for robust physical security measures and regular key rotations in both HSM and non-HSM environments.
- **Participant C:** Discussed governance issues, including key transfers during mergers and acquisitions and the role of third-party management.
- **Participant D:** Shared insights from audit experiences, identifying red flags such as founders having access to key material.
- **Chloe:** Provided a regulator's perspective on the importance of focusing on catastrophic risks rather than just tidying up definitions.

The session concluded with a clear plan for moving forward and a reminder about the break before the next session.

Detailed Session Summary

of the Session

Introduction and Context Setting - The session begins with participants discussing the adoption of new key management practices in various jurisdictions, particularly focusing on the challenges faced by exchanges. - A key point is raised about the importance of standardizing terminology to avoid confusion among policymakers and market participants.

Discussion on Key Management Practices and Security Considerations - Participants delve into specific examples of how different exchanges manage their keys, including both HSM (Hardware Security Module) and non-HSM environments. - The discussion highlights the need for robust physical security measures, such as secure rooms for key ceremonies, and the importance of regular key rotations and backups. - There is also a focus on the potential risks associated with human factors, such as executives having access to key material, and how this can lead to vulnerabilities.

Addressing Governance and Compliance Issues - The conversation shifts to governance issues, including how to handle key transfers during mergers and acquisitions and the importance of clear governance provisions. - Participants also discuss the role of third-party management in ensuring the security of transactions and the need for standards bodies like ISO and IEEE to align with industry practices.

Conclusion and Next Steps - The session concludes with a consensus on the need to develop a taxonomy and lifecycle framework for key management practices. - There is a call for contributors to help in this effort, emphasizing the importance of focusing on practical use cases that have real-world impact. - The discussion ends with a brief overview of the next steps and a reminder about the break before the next session.

The meeting focused on advancing key management practices, particularly in the context of exchanges and their operational challenges across different jurisdictions. Key topics included the standardization of terminology to ensure clarity among policymakers and market participants, as well as an in-depth discussion on security considerations for both HSM (Hardware Security Module) and non-HSM environments. Participants emphasized the importance of robust physical security measures, such as secure rooms for key ceremonies, regular key rotations, and backups. The human factor was also highlighted, with a focus on mitigating vulnerabilities associated with executives having access to key material.

The conversation then shifted to governance and compliance issues, including best practices for handling key transfers during mergers and acquisitions and the role of third-party management in securing transactions. There was a strong call for standards bodies like ISO and IEEE to align their guidelines with industry practices. The session concluded with a consensus on the need to develop a taxonomy and lifecycle framework for key management practices, along with a call for contributors to focus on practical use cases that have real-world impact. The meeting set clear next steps and reminded participants about the break before the subsequent session.

Appendix: Full Meeting Transcript (Anonymized)

28.6 --> 30.0: This is a meeting transcript.

34.6 --> 43.1: And we believe that customer protection is going to be more important for cyber, for like crypto asset space.

43.8 --> 50.9: And one of the ways of protecting customers is, of course, to strengthen cyber security.

50.9 --> 63.0: And this is the policy that JFSA has made a commitment to do.

64.2 --> 71.4: And so I already talked about the background in the upper side.

71.4 --> 88.8: And looking at the bottom of this slide and on the right side, it is written that we are going to analyze past domestic and overseas cyber attacks.

88.8 --> 99.3: We're going to do that research as an international joint research project, which we started in 2020.

100.1 --> 104.4: And this is the seventh or eighth project as JFSA.

104.4 --> 115.9: And we did a lot of research like AML, CFT for stable coins and embedded supervision for cryptos and for blockchain related services.

116.9 --> 123.1: And, you know, this year, the research scope is cyber security.

123.5 --> 128.6: And we are doing a case analysis of past cyber attacks.

129.6 --> 132.1: And. OK.

135.6 --> 147.2: So we do we are doing the research in collaboration with Deloitte, Tomas, LLC, and the research purposes and contents.

147.2 --> 158.4: So. The first purpose is that so we assume that, you know, governments know, you know.

159.5 --> 169.1: The crypto service providers are struggling to translate on existing guideline, existing abstract guidelines into practices.

169.1 --> 187.6: And so they it would be we are thinking that if we're going to do the case studies, case analysis, we're using the existing cyber security standards like NIST guidelines or like JFSA guidelines.

188.0 --> 194.8: It would be probably helpful for cryptos and service providers which have license in Japan.

194.8 --> 205.4: And also like looking into the details of the case study with the use of these cyber security standard.

205.8 --> 224.0: It would be probably insightful in terms of finding out what are the risks like crypto asset service, crypto related specific risks that are not still covered yet by existing guidelines.

224.0 --> 230.8: So. We started from comprehensive industry structure assessment.

231.4 --> 243.1: So we visualized all of the key players in the ecosystem so that we will be able to get a good understanding of like what are the supply chains in the crypto asset ecosystem.

243.1 --> 259.0: And then we started we did a case study analysis of the past, you know, cyber incidents like Bybit incident, Swissborg incidents and Balance V2 incident and these types of like biggest ones.

259.8 --> 272.0: And then we generated, we analyzed, you know, what are the crypto assets specific risks based on the case study, which is what we did.

273.0 --> 282.2: And we received a lot of feedback to this research from at the JFSA roundtable.

283.0 --> 293.9: And I am now trying to summarize and, you know, prioritize what we need to revise based on the discussion we had.

293.9 --> 298.6: So it's not done yet. So I'm going to just go through the slides.

299.0 --> 309.2: But this is, you know, mapping of key stakeholders, key players in the crypto assets ecosystem.

310.2 --> 337.3: And I think it is very similar to like what we, what Bin did for the information sharing project, because when we created the chart and the steps for each stakeholder to take to, you know, share threat and vulnerability information, we did the same thing.

337.3 --> 362.0: But we wanted to redo that because I think it is, this map is intended for like understanding what are the key players, key stakeholders surrounding the crypto service assets, crypto assets service providers that are regulated under the JFSA regulation.

363.0 --> 389.7: And yes, and I'm not going to talk about the details of this, but based on this, we kind of generalized what are the, you know, attacks types that are often used for targeting CEX, centralized exchanges and unhosted wallet and also DeFi protocols.

389.7 --> 408.4: And then we did a case analysis and, yeah, we got a, I got a lot of feedbacks on, you know, what are the, what like past cyber incidents should be analyzed in the JFSA roundtable.

408.4 --> 427.1: And we talked about it and one of the good insights we got is like we focused on only the biggest, you know, incidents, but it should be, we should also be focusing on like, you know, small incidents that would be sometimes like insightful.

427.1 --> 447.9: So that's one of the takeaways that we got from the roundtable. And also I showed the list of referenced guidelines that are used, guideline referenced in the case analysis and it's not comprehensive enough.

447.9 --> 471.6: And yes, there are some guidelines that are, you know, mentioned in the roundtable like HKM and like CCSS. And so we are going to look into it as them as well. And yes, and we did these case studies like by bit.

473.2 --> 500.9: Yes, I don't think we, I should go through what happened when by bit incident, what happened in the by bit incident by, yes. So, you know, it started from social engineering and the session token used for the AWS, what access was stolen and JavaScript file in the AWS.

501.6 --> 524.3: Was modified by the attacker and transaction, the by bit sender, by bit signer didn't really notice, you know, that the UI was modified and the signer's screen displays very, just a ridiculous transaction details and didn't notice it.

524.3 --> 540.7: The modification, even though the transaction was modified as an upgraded transaction instead of the transfer transaction that the signer intended to sign.

540.7 --> 568.6: So, and malicious transaction was broadcast on chain and it directed to, it was directed to the malicious contract and the attacker changed the smart contract immediately right after the transaction happened and they drained all of the funds through the smart contract.

568.6 --> 597.7: So, and what we did is like we, you know, sorted out the timeline of the attacks and also like what we did was, so based on the thing, based on the challenges, based on the challenges we identified, we kind of mapped the existing guideline.

597.7 --> 603.6: Like in NIST, JFSA guideline, FISC guideline, which is also a Japanese guideline.

603.6 --> 633.0: And so, this is, this might be helpful for cryptoservice providers to understand like actually everything is written, even though it is abstract in the existing guidelines, but maybe when it comes to thinking about, you know, covering all of the cryptoset related specific risks.

633.6 --> 640.2: It will be not enough in terms of the, you know, concreteness.

640.2 --> 643.4: So, yes.

644.0 --> 650.4: So, there are a lot of feedbacks in terms of that perspective as well.

650.4 --> 677.1: But, yeah, and I think it's a good idea to look into other guidelines, such as guidelines that are set by Hong Kong and also HKCSS and other guidelines, which is targeting like node operators.

677.1 --> 687.6: And I, yeah, I'm going to look at, I'm going to summarize all the points made in the JFSA roundtable anyway, but yes.

688.0 --> 700.9: So, it's not comprehensive enough, I believe, but it would be great if once I revise this slide, it would be great if we're gonna,

703.9 --> 719.5: I would appreciate it if you could, you know, look at the slides that I've revised and, you know, get, I would like to get a feedback on this, like from you all, from the beginning people.

719.9 --> 720.8: So, yes.

720.8 --> 731.2: And we did the same case study for Swissborg and so, yeah.

732.1 --> 746.0: And I, you know, when it comes to analyzing the attack techniques that are used in the incidents, we also are trying to use MITRE framework, like ATT&CK, ADAPT,

746.0 --> 763.6: and also someone from MITRE also joined the roundtable and they said that, you know, we should also look into the defense framework as well, which is what we are going to do as well.

763.6 --> 766.0: So, yes.

766.6 --> 777.8: And we did the same thing, like, you know, we mapped the existing blank lines to the challenges we identified through the incident.

779.6 --> 781.0: And, yeah.

782.9 --> 800.3: Yeah, we are going to kind of make a list of, you know, cryptoasset specific risks we identified through those case studies and, but it's not, you know, it's not the work that we have done yet.

800.3 --> 809.9: So, this is just an ongoing research and we presented this for just discussion purposes and we got a lot of feedbacks.

810.2 --> 819.6: So, yeah, I don't know if it is helpful, but this is an overview of what we are doing at JFSA and Deloitte Research.

819.9 --> 821.1: So, yeah.

826.0 --> 826.9: Thank you.

826.9 --> 832.2: Well, it is, well, for those who were there on Friday, we found it useful.

832.3 --> 841.1: I think it was quite a common comment made by the roundtable participants and I'm sure it is useful also for the group today.

845.3 --> 855.6: Well, the sooner you are able to share an updated version, the better for us from our point of view, from what we discussed this morning.

857.6 --> 869.6: And we, I think we will also recommend, if this is ever possible, to make a good document available as soon as you can.

869.7 --> 874.4: I mean, it's really a valuable contribution from FSA on those topics.

874.7 --> 885.4: So, if you have something at some point, either for BEGIN or for, as a public version that BEGIN can refer to, I think it would be helpful.

885.4 --> 895.6: This morning, we discussed about considering those acts, identifying, well, the attack vector, of course.

896.5 --> 907.4: Identifying respect to the attack vector, the mitigation or control that would have been helpful to avoid those attacks to happen.

907.4 --> 925.9: And then working on mapping the different frameworks with respect to security controls that need to be followed by the organization, the developers, the system providers, the service providers as well, or exchange, for instance.

926.3 --> 931.4: So, being able to refer to this kind of work could be very useful.

933.7 --> 938.3: So, let me share the schedule of this research.

938.8 --> 950.9: So, the contract with Deloitte will finish at the end of this month, but I don't think I will be able to, you know, reflect all of the points made in the roundtable.

950.9 --> 964.6: And I will revise the slides with Deloitte, and I think, I hope we will be able to show the revised version at the end of this month or, like, next month.

964.7 --> 975.2: And it would be great if we have some sort of workshop or, like, you know, one-hour, like, Zoom call to, you know, get another feedback again.

977.6 --> 982.8: And based on that, we would like to revise the slides as well, again.

983.2 --> 991.0: So, yes, if we could do it at the beginning as well, it would be pretty nice.

993.3 --> 999.2: Well, I think it's quite, it fits quite well with what we want to work on.

999.5 --> 1002.6: So, it should be, we will find a way, I think.

1005.2 --> 1011.7: Any questions for Takaya, from you guys, or online?

1032.9 --> 1035.3: Okay. Thanks. Thanks again. Thanks a lot.

1037.9 --> 1045.8: With this, we can come back to the offline key management topic.

1048.5 --> 1052.1: And we may start with Daniel, if you want.

1052.8 --> 1058.5: Daniel, are you connected on Zoom, or are you able to connect on Zoom?

1058.8 --> 1063.1: Or do you want to send me your presentation? I would, I mean, as you like.

1091.4 --> 1092.8: Okay.

1122.1 --> 1123.5: Okay.

1139.1 --> 1140.4: Recording in progress.

1183.8 --> 1185.2: Recording in progress.

1200.4 --> 1205.6: Hi. So, I wanted to address the offline key management component.

1206.6 --> 1209.0: I was told not to shill or anything.

1209.3 --> 1214.0: So, I'm just going to be kind of roundabout in regards to what offline key management is.

1214.0 --> 1220.3: And the solution that I want to talk about today is more around HSMs.

1220.9 --> 1228.5: There are many vendors around the HSM industry, or there is offering.

1229.2 --> 1238.3: With that said, whether it fits the big blue IBM, or TALS, or even a Swiss-based solution called Skurosis,

1238.7 --> 1241.2: they all offer great HSM solutions.

1241.2 --> 1244.4: They all come in different price ranges as well.

1245.6 --> 1256.5: They all do have the support in regards to all the certifications, whether if it's FIPS 140 levels, SIP 142 levels 3.

1256.9 --> 1267.2: It also supports different encryption algorithms as EAL4, or plus with EDIS and whatnot.

1267.2 --> 1278.2: And this allows for basically all the cryptocurrency assets to be sitting there, whether if it's Bitcoin, Ripple, or ADA in that sense.

1278.6 --> 1288.2: With this, it's basically a secure generation and storage of the actual keys.

1288.9 --> 1299.7: The idea or the model is that it does not - the actual people that are signing, let's say, a smart contract or anything,

1299.9 --> 1302.8: they don't actually have the private keys or whatnot.

1303.5 --> 1313.3: They all basically - the private keys or anything of any nature for any of the signing aspect is all stored in HSMs.

1313.3 --> 1319.3: And being able to then unlock the keys would have specific signers.

1319.9 --> 1329.0: Even if the chief security officer has the overall control, he himself cannot execute any transactions without any other signing -

1329.0 --> 1330.8: counterparty signers in that sense.

1331.1 --> 1335.4: And with this, it is a very secure solution in that sense.

1335.4 --> 1342.6: Just think of it as that scene in war games in the 1980s where when you want to launch a nuclear missile,

1342.8 --> 1349.8: you have to get the actual phrase as well as the pin code and flip the key.

1350.7 --> 1355.2: There's the security components around this where it makes it very secure.

1356.8 --> 1367.2: HSM implementations usually takes away the attack vectors up to around 90% of the attack vectors that are well-known

1368.4 --> 1373.8: that the FSA has kindly offered in our previous presentation.

1374.8 --> 1379.5: The other 10% is basically much to human error in that sense.

1379.5 --> 1392.0: With this said, HSM is the next idea or the security model that we would like to see more of in circulation

1394.0 --> 1400.7: because the world and the threat matrix is evolving constantly.

1401.3 --> 1407.9: And to be able to have not one person or any parties involved have access to the keys

1407.9 --> 1413.5: and if anything, put it on a secure black box in a trusted encrypted environment

1413.5 --> 1418.4: where to only unlock is the registered signers of said things

1418.4 --> 1425.9: and they all have to do it within a certain time frame and unlock these certain keys to execute a transaction in that sense.

1427.5 --> 1438.2: So with that said, most of these HSM solutions, their key drivers is mostly compliance driven.

1439.2 --> 1449.4: What we've noticed with a lot of the HSM adoption is most is through let's say Europe and significantly out in Hong Kong.

1449.4 --> 1456.3: We've noticed a lot of the GDPR aspects, a lot of the

aspects from finance, payments and even health.

1456.4 --> 1461.5: They all have the requirements to store secrets in this black box.

1463.9 --> 1472.9: And to have that responsibility of signing signatures, of signing cryptographic signatures is a big responsibility at that

1472.9 --> 1478.9: and having it given to one sole person is a big responsibility that no one wants to take at night.

1478.9 --> 1488.1: And so being able to shard that responsibility amongst many people and sign it is where the industry should be going

1488.1 --> 1490.7: and will probably end up going in that sense.

1491.3 --> 1499.6: And this allows for that whole privacy aspects, the complete ownership, the sovereignty and basically the IP protection.

1499.6 --> 1508.6: And it can be able to help drive all that aspects and it applies to various verticals.

1513.1 --> 1522.5: And all HSM solutions have that cyber protection aspects of verifiable authenticity, blacklists, whitelists,

1523.5 --> 1531.1: most specifically whitelists in regards to what wallets can be transacted through it and be pre-programmed in this

1531.1 --> 1535.1: and be able to avoid the Bybit situation.

1535.7 --> 1546.1: And if let's say Bybit had a solution like this, used HSM, they would have avoided a misdirected transaction

1546.1 --> 1552.0: and the system would have caught it in advance in that sense.

1553.8 --> 1559.3: This allows for a lot of the data breaches and a lot of the access controls at certain places.

1560.5 --> 1569.5: A lot of the HSMs, they're just huge black boxes that encrypts a lot of the information and the keys.

1569.5 --> 1578.8: You can have several partitions on these HSMs so you can segregate wallets and or accounts accordingly

1578.8 --> 1583.5: and with that you can do access controls of who can get access to what partitions.

1584.3 --> 1586.3: So the technology is there.

1587.2 --> 1594.9: Originally, I mean, I had the opportunity to initially work on the first iteration back in 2016

1595.9 --> 1601.0: when we were working in a working group with IBM, Intel, and NTT DoCoMo.

1601.1 --> 1611.6: I represented NTT DoCoMo back then where we were working on the security enclave component of how the future of how security

1611.6 --> 1617.4: and how mobile and communications as well as how secrets are kept.

1617.4 --> 1624.4: And with that said, we drafted three documents that are now currently published but probably now outdated.

1626.0 --> 1635.3: But the foundation level, it led for a good foundation level for what see how HSMs are currently designed to do.

1635.7 --> 1640.7: And with this, it's good to see that the industry has evolved over time

1640.7 --> 1650.6: and naturally with the threat of the quantum aspects,

most HSM solutions now have that quantum threat addressed in that sense.

1651.2 --> 1662.4: So aside from the chain in itself but all in all, it is kind of forward thinking and it is a security model to consider

1662.4 --> 1673.3: when approaching kind of the regulatory and the compliance aspects of what's the best practices in your security solution architecture.

1680.4 --> 1681.9: Good. Thank you.

1682.8 --> 1692.2: Maybe before launching the discussion, I would like to present a short overview of this topic of offline key management.

1693.5 --> 1702.7: Definitely HSM is a very solid foundation but we have seen in the industry many other practices.

1704.1 --> 1711.5: Sometimes just maybe because they cannot afford an HSM, although there are some options now to have something which is quite affordable

1711.5 --> 1715.6: depending on the constraints in terms of boundaries and extra.

1715.8 --> 1721.7: But I would like to make an intro and to mention a few other topics.

1722.0 --> 1725.1: But before that, if you have any questions to Daniel, please feel free.

1731.6 --> 1741.1: So while some people come up with questions around this, how let's say an exchange uses an HSM, I can probably talk about that.

1741.6 --> 1746.6: So how it works is that there is a CSO, a chief security officer.

1747.1 --> 1751.3: He orders a unit and basically deploys it out.

1751.3 --> 1757.3: He delegates signers for this HSM unit.

1757.7 --> 1764.0: They are all given smart cards and the owners of said smart cards have to come up with their own unique pin code.

1765.3 --> 1772.1: The CSO has only the access controls to delegate said signers and undelegate signers in that sense.

1772.1 --> 1780.8: He himself does not have controls to override any transactions or anything of that nature in that sense.

1782.3 --> 1791.2: But the CSO also has the rights to do the rotation of keys if necessary if they have been compromised in that sense.

1792.4 --> 1801.2: Now the delegation for the signers, they have to punch in their smart card into the unit as well as the pin code.

1801.2 --> 1803.7: And then do the signing process.

1804.3 --> 1815.3: And once those delegated signers sign it, then the transaction, the private key is unlocked within the security enclave of this HSM.

1815.5 --> 1819.0: And allows for the transaction, whatever that needs to take place.

1819.8 --> 1825.2: It's a pretty well thought out solution and it's very logic driven in that sense.

1826.9 --> 1835.6: Once they've done the transactions, the usual practice is that they unplug the box literally from the power and they turn it offline.

1835.9 --> 1838.5: It's either in their data center or whatnot.
1838.8 --> 1839.6: It's not connected.
1839.9 --> 1841.6: It's always in a cold state.
1841.9 --> 1848.6: They only turn it on when it's required to actually make a transaction or do any signing of any sort.
1851.4 --> 1852.6: Yeah, good insight.
1853.6 --> 1861.7: You mentioned to me earlier that you are not there to self-promote, but I will do some promotion on Securosis.
1862.2 --> 1873.6: From my experience, from what I remember, when I started to look at some HSM solutions for crypto assets in 2017, I think,
1874.6 --> 1883.3: they were among the first ones to be compatible with the cryptographic requirements for signing.
1883.9 --> 1889.6: So, both algorithms and the key size needed for crypto assets.
1889.6 --> 1904.4: Because HSM were used before mostly in banking environment for a very specific usage, using RSA kind of signature related to P CI DSS.
1904.7 --> 1910.0: And they were really starting to focus on application to crypto assets at that time.
1910.2 --> 1916.9: So, I guess now there are different players, but at least those guys, you have been working on it since quite some time.
1917.0 --> 1919.0: So, it's good to have you on board as well.
1919.0 --> 1919.7: Thank you.
1920.1 --> 1920.5: Thank you.
1920.9 --> 1927.0: Yeah, so we're seeing actual good adoption, I think, in regards to the Hong Kong regulatory aspects.
1928.0 --> 1933.4: We actually worked with the regulators in Hong Kong in designing that framework,
1934.0 --> 1941.6: where HSM is used in the whole process of the whole architecture of things in the security model.
1941.6 --> 1955.9: And how the exchanges and or banks to not only be to mitigate these risks, but also quantum proof their solutions for the key management.
1957.4 --> 1964.1: And so with this, we looked at many HSM vendors as a system integrated here in Japan.
1966.0 --> 1971.2: And the one that's the most affordable, we've just found that Skurosis was the affordable one in that sense.
1974.2 --> 1979.7: I posted the link. I think, Mickey, this is the link that you sent for the guidelines for Hong Kong.
1981.8 --> 1983.1: I posted it on the chat.
1983.2 --> 1984.1: Okay, thank you.
1984.7 --> 1988.0: So, let me share my screen.
1988.1 --> 1991.3: And of course, if you have follow-up questions, everyone feel free.
1994.1 --> 1994.9: Where is it?
1996.1 --> 1997.2: Here, okay.
1998.2 --> 2009.2: So, I will not remind everything because you already

mentioned a few things, but let me just highlight a few topics that we may discuss.

2009.8 --> 2013.2: If I'm able to go to the next slide.

2013.9 --> 2014.1: Yes.

2015.1 --> 2028.3: So, when we talk about offline key management, quite often this, well, it has been in the crypto industry, mentioned under the term of cold storage.

2028.5 --> 2033.8: Although we can debate whether this is really cold storage or not, but it's very often mentioned this way.

2033.9 --> 2041.0: So, there are the hardware wallets in the broad sense or either consumer versions or HSM.

2042.2 --> 2046.8: Let's say the HSM is the enterprise version of the smart card in a way.

2047.0 --> 2052.0: So, we have the same analogy in the crypto space.

2052.5 --> 2062.6: We have the RGAP systems, something which is never connected in principle, at least to a network and so on, and might be in a secure room.

2063.5 --> 2066.5: We have a fully offline execution environment.

2067.0 --> 2070.6: Well, some nuance with RGAP, but it's kind of related.

2070.6 --> 2089.7: We have sometimes a key which is managed fully offline, but the transaction is not, in the sense that validation of the transaction to be signed is done online and then you sign offline.

2089.7 --> 2102.2: But then you have also processes where the transaction validation, when this is considered very sensitive or critical, is also validated offline to avoid any kind of alteration of the process.

2103.5 --> 2116.5: There are some stuff that are not really cold storage, but I think it's worth to mention them because they are often pushed forward by the community as a way to secure further the keys,

2116.6 --> 2122.1: what is more interactive like multi-sig, special base signature or secure computation.

2122.8 --> 2131.6: And then you have hybrid models where, for instance, you may rely on HSM to secure the keys that are used in multi-party computation, for instance.

2134.8 --> 2143.9: So, very brief reminder of the threats that we are looking at in general with respect to offline key management or cold storage.

2144.6 --> 2153.9: Well, of course, remote attacks, supply chain, insider threats, but we are also considering physical attacks, which is going kind of a step further.

2155.8 --> 2168.3: And in physical attacks, we are also considering physical or environmental threats in general, like, I mean, what happens if there is a fire in the data center, for instance.

2169.7 --> 2172.7: Redundancy in that case might help, of course.

2173.9 --> 2178.8: But the question is how to do redundancy while still keeping the keys offline, for instance.

2180.2 --> 2187.0: I will skip the HSM topic because, of course, we already had a presentation on this.

2188.3 --> 2192.6: Then, quite often, there are comparisons between AirGap and MPC.

2193.1 --> 2208.0: So, MPC for multi-party computation were claiming that, for instance, well, claiming this is a fact, but AirGap, you keep the key isolated in an AirGap computer, for instance, or AirGap environment.

2208.8 --> 2219.9: Multi-party computation, you have only shards or shared version of the keys, which are across multiple locations.

2223.0 --> 2231.4: Communication for AirGap side, generally, this is manual and it's made on kind of ad hoc basis, while for multi-party computation,

2231.4 --> 2239.3: you need some interactions to be able to sign through the secure multi-party computation protocol.

2239.6 --> 2248.6: So, even if the keys are separated, you need things to be communicated, although the communication itself is known by construction to be secure,

2248.8 --> 2252.0: which means that there is a connection to a network in a way.

2252.3 --> 2256.9: So, we're protecting the keys with something like HSM makes sense, for instance.

2256.9 --> 2267.0: The speed can be compared, I mean, the more you are offline and involving manual processes, the slower it is, makes sense.

2268.0 --> 2271.9: So, that's why multi-party might be seen as something faster.

2272.5 --> 2282.4: Okay, which is, of course, this is faster, but depends on the number of parties and how many shards you are using and a few nuances.

2284.5 --> 2288.4: When we talk about different solutions for cold storage,

2288.8 --> 2294.5: if you have one single copy of your key somewhere in an isolated environment, that's good,

2294.6 --> 2299.5: but if you are losing access to this environment or something is just burning,

2299.6 --> 2308.1: then, of course, single point of failure issue with respect at least to the access to the key, if not stolen, depending on how it's protected.

2308.1 --> 2316.8: And while you are sharding, backupping, having different ways to retrieve the access, it's a different story.

2317.3 --> 2324.1: That's just to set a few things. I'm not trying to be exhaustive, just to set the scene.

2325.1 --> 2343.7: Something which is quite often mentioned in offline key management situation or cold storage is, from an individual perspective, of course,

2343.7 --> 2354.6: things like seed phrase or passphrase recovery, often seen as a burden for, let's say, larger system geographic redundancy,

2356.2 --> 2364.6: different backups, different geolocation, different governance control, etc.

2365.6 --> 2372.3: When you use either secure multi-party computation or

things like Shamir secret sharing,

2374.0 --> 2384.6: what is put in front as a benefit, of course, is being able to have only pieces of your backup in order to retrieve the backup.

2387.7 --> 2401.7: Things like, here it's illustrated in the case of a smart contract, but the dead man's switch is how to retrieve the access in case the main proponent having the right to, for instance,

2401.8 --> 2407.2: to do the revocation or to launch the recovery process is not available anymore.

2408.2 --> 2415.8: That could be an issue that you have to think of in advance because when it's needed, that's an issue and a few other things.

2418.2 --> 2421.3: Just saying this for one reason.

2422.8 --> 2434.5: Something that is quite often underestimated is that we tend to think about offline key management or cold storage only for key generation,

2435.2 --> 2442.6: but really only the technical part of the key generation and then signing the transactions.

2443.1 --> 2446.4: But at the end, it's really about the whole lifecycle management.

2447.2 --> 2463.0: How you create it properly, how you distribute your keys, how you use it, of course, how you store it, how you do the rotation.

2463.0 --> 2471.8: You mentioned it, Daniel, how you do the revocation, how you destroy your key at some point, although that might be easier in that case.

2472.0 --> 2482.2: But how you do the backup, how you do the backup and both distribution and if you really want things to be kept offline, let's say,

2482.3 --> 2488.5: offline in the sense at least protected from the external environment, that could be sometimes a nightmare.

2488.5 --> 2501.6: The same, some very specific key generation procedure can be a nightmare to manage in the sense that it's not just about the technical generation itself.

2501.7 --> 2507.4: But for instance, let's take the example of the HSM.

2507.4 --> 2517.1: If you need specific cards from different persons to launch the generation of keys within the HSM,

2518.1 --> 2524.3: questions that will come are, for instance, how you are sure at the very beginning that those persons are the right ones.

2524.3 --> 2530.4: Well, generally, in an enterprise situation, it's quite well resolved.

2530.7 --> 2538.4: But the smart cards needed for launching the key generation, are they well protected in advance?

2538.7 --> 2544.4: Are you controlling the full supply chain to get the smart card to be delivered to the right person, etc.?

2544.4 --> 2551.1: Those are nuances, again, I'm not trying to be exhaustive here.

2551.1 --> 2554.8: Let me switch to the next one.

2559.1 --> 2565.0: At the end, it's all about the quality of the lifecycle management overall.

2565.5 --> 2572.8: You have things like the key protection, resilience in operational conditions, governance around this, threat resistance.

2574.9 --> 2581.0: This is where Daniel was saying that basically the HSM is doing almost everything integrated.

2581.4 --> 2590.7: While if you are trying to build the process by yourself, for instance, buying a smart card, a second smart card, a third smart card in order to protect your keys,

2591.2 --> 2593.4: how do you control the management of the smart cards?

2594.3 --> 2597.7: This is something which is not by default, so you have to write processes.

2597.7 --> 2602.9: If you write on an existing overall system, then it's a different story.

2616.8 --> 2621.2: Before discussing this, I just want to highlight something.

2625.5 --> 2635.5: A few years ago, while discussing issues with respect to lifecycle management for offline key management,

2635.7 --> 2638.5: it was not necessarily related to the use of HSM.

2638.8 --> 2644.8: We were trying to address scenarios where there is not necessarily HSM available,

2645.4 --> 2649.7: but still the need to do it properly in terms of offline key management.

2649.7 --> 2654.3: I was involved in the working group in Crypto Valley in Switzerland,

2655.8 --> 2659.8: and we worked on a guideline for the key ceremony itself.

2661.8 --> 2669.5: Trying to reuse what was known as a good practice,

2669.5 --> 2677.5: or what is still known as a good practice for the key ceremony use for all the internet infrastructure,

2677.6 --> 2680.1: for the DNS infrastructure in particular.

2681.2 --> 2685.3: How it has been done properly, how things have been kept offline securely.

2692.8 --> 2696.4: We wrote a guideline around this topic.

2696.4 --> 2700.2: I can share the link, I'm sure we'll be able to find it.

2702.3 --> 2706.7: Just reminding the goal of a key ceremony, what happens, what should be taken into account,

2706.9 --> 2714.2: how to be sure that the key ceremony worked well, how we should be prepared,

2714.9 --> 2720.4: how everything should be scripted properly, who should participate,

2721.2 --> 2727.8: which kind of software and hardware are used, how to properly manage those equipments,

2729.0 --> 2733.7: how to be sure that everyone is trusted, backups are generated properly,

2734.2 --> 2737.7: checking that the generation worked well, all those kind of things,

2737.8 --> 2740.7: just because we realized it was not really well described

ibed.

2740.8 --> 2746.0: It was known by practice how to proceed, but at least in the crypto industry,

2746.0 --> 2753.0: those ceremonies were not really respected, so we felt that it was needed to define something.

2756.9 --> 2765.1: There were discussions around, I'm not sure if I will be able to find it back,

2765.1 --> 2777.1: but there are discussions around if you do it in an environment that is not secure by design,

2777.3 --> 2785.1: like if you are not using an HSM, where you have some level of assurance that keys are not going out of the HSM,

2786.8 --> 2794.6: how do you ensure that this is the proper software that has been installed in the computers that you are going to use?

2795.1 --> 2799.5: How do you ensure that it has not been altered when you are running the generation process?

2799.9 --> 2803.4: How to ensure that everything is really kept offline?

2804.5 --> 2810.1: Obviously, you don't want things to be online, in particular distributing the backups,

2811.1 --> 2814.8: how to be sure that they are distributed properly, and so on.

2815.2 --> 2821.1: And when you start to want to be sure that it's really offline end-to-end,

2821.7 --> 2831.8: this is where I realized that you may want to rely on some systems that are already kind of isolating everything,

2831.9 --> 2833.8: a part of the process, in order to limit it.

2833.9 --> 2842.3: But even when you rely on some secure hardware, on secure software embodiment,

2842.6 --> 2846.4: then you still need to take care of a few things.

2848.5 --> 2857.1: So, coming back to our topic.

2869.7 --> 2879.4: As far as I know, and as far as some other participants in BEGIN are aware of,

2879.4 --> 2896.2: there is not today any standard describing what should be proper processes and proper practices for offline key management in the crypto asset industry.

2897.8 --> 2901.7: So, we thought there's probably something on which we can work on.

2902.4 --> 2903.5: Some ideas.

2904.9 --> 2911.2: Well, maybe starting with the one in the center, taxonomy of what is offline key management,

2911.6 --> 2920.4: or called storage, might be needed to have something which is cleaning a bit all the buzzwords, the trends,

2920.6 --> 2925.5: and trying to explain properly, well, this one is only offline key generation,

2925.5 --> 2931.9: this one is offline end-to-end, this one is a principle for protecting the execution,

2932.2 --> 2934.2: but it's not really offline, etc.

2934.5 --> 2937.1: Well, it could be helpful.

2938.7 --> 2944.7: Another one that I see which is, I think, quite useful is the whole lifecycle management,

2945.0 --> 2954.5: to describe the different steps and what should be probably cautiously managed at each step,

2954.5 --> 2956.0: at each of the steps.

2957.2 --> 2967.9: And then, maybe further down this journey, maybe at some point going up to a checklist for some specific use case,

2968.1 --> 2975.8: like secure custodian, what should be checked, which is kind of related to what you shared,

2976.0 --> 2984.3: what you have done for the Hong Kong case, but I don't think it does exist in a standard at all today.

2984.5 --> 2987.7: So, it might be interesting as well.

2988.4 --> 2989.7: Any thoughts, any comments?

2990.2 --> 2991.1: Julian, can I jump in?

2991.2 --> 2998.3: So, I was in this session because I need to do the US DC payment for the coffee today,

2998.8 --> 3001.5: at the 10th floor, that is a fun experience.

3002.3 --> 3010.5: So, I would like to bring what we discussed in the morning session for the competition for the key management.

3011.5 --> 3020.9: At that moment, we had a very interesting brainstorming discussion about how we design that technology competition,

3021.6 --> 3024.2: three-year technology competition from now for the key management.

3025.2 --> 3029.8: At the moment, I would like to explain the current Japanese regulation.

3030.3 --> 3039.0: The Japanese regulation, so the custodian or cryptocurrency exchange need to store 95% of their assets in the cold wallet.

3040.6 --> 3044.8: From a risk management point of view.

3045.7 --> 3056.0: So, it's kind of the source of their complicated operation inside the custodian.

3058.8 --> 3069.1: Ironically, it could be that it produces a complicated human operation or sabotage of some security risk operation.

3069.8 --> 3072.2: It could be the source of the new attack.

3073.0 --> 3077.2: That is what was observed two years ago.

3079.8 --> 3082.7: It's a Chatham House discussion.

3083.7 --> 3092.6: I think that 90% cold wallet reserve restriction is too bad.

3093.5 --> 3099.4: I'm sorry, that produces too complicated operation in side.

3101.4 --> 3119.0: But, the current JFSA's regulation is inspired by the very old-fashioned vault system in the bank branch or something like that.

3119.2 --> 3125.9: It's a segregation of the money in the strong vault system.

3125.9 --> 3133.3: So, it's an easy concept for JFSA people to understand.

3135.1 --> 3141.2: But, I don't know the correct definition of the cold

wallet, hot wallet, warm wallet.

3141.4 --> 3141.8: I don't know.

3142.3 --> 3150.4: For JFSA people, offline means not connected to the internet.

3151.5 --> 3153.6: Online means connected to the internet.

3153.6 --> 3154.2: That's it.

3155.1 --> 3157.2: It's understood by regulators.

3157.6 --> 3158.5: Not technology terms.

3159.6 --> 3161.0: It's easy to understand for regulators.

3162.7 --> 3174.8: So, if we imagine the entire digitalized world, it should be the concept of access control to the key or something like that.

3174.8 --> 3183.1: We need to reinvent the world to our discussion near to the access control mechanism.

3183.3 --> 3191.3: We can create a more innovative way to better access control than the 95% cold wallet or offline wallet or something like that.

3191.7 --> 3198.9: But, that is the most important part to design the three years competition from now.

3199.2 --> 3201.7: To design a new way of offline key management.

3201.7 --> 3202.6: No, no.

3203.2 --> 3205.7: Key management for the custodial, key management for bus.

3208.7 --> 3219.4: That is my comment and my thing to bring to this session from the morning session we discussed.

3221.5 --> 3222.3: Thank you.

3223.7 --> 3224.6: Thank you for the insight.

3224.7 --> 3227.9: Based on what you have here.

3229.0 --> 3231.2: Which is only draft proposal.

3231.7 --> 3231.9: Sure, sure.

3232.4 --> 3235.2: The first two makes a lot of sense to me.

3235.8 --> 3247.4: The third one, I think we do need to compare what has been done under the GCFFC, which is the Global Coalition for Fighting Financial Crime.

3248.0 --> 3255.3: The subcommittee, I think it's the DeFi or it's one of the crypto subcommittees, is working on a checklist.

3255.9 --> 3260.4: And, it's mainly the compliance officers of many of the crypto exchanges.

3260.4 --> 3264.0: So, we just might want to check what other groups are doing.

3264.1 --> 3269.3: Because, I actually think they're best placed to do at least some of the compliance checklist work.

3269.9 --> 3277.5: In that way, hopefully, all these bodies of work can meet and be standardized over time.

3277.9 --> 3280.7: But, I know there's been a lot of discussion about the last one.

3281.2 --> 3284.9: About there being some kind of compliance checklist in different categories.

3287.4 --> 3288.1: Thank you.

3290.4 --> 3294.0: To me, it's kind of related to a comment made by Shin ichiro as well.

3296.1 --> 3309.8: We may need to provide at least nuances in the technical implementation to achieve some of the compliance requirements.

3310.0 --> 3312.9: Like, what does it mean 95% in cold?

3312.9 --> 3317.1: Does it mean there is really 95% in cold storage?

3317.5 --> 3326.1: Or, there is basically only 5% of the overall total of assets that can be transacted in 24 hours, for instance.

3327.4 --> 3334.7: It could be a nuance where you can start to explain, well, yes, everything is kind of online.

3335.0 --> 3341.3: But, by design, the system is blocking when you have more than 5% of the transactions.

3342.0 --> 3346.3: And, of course, you have to explain how it can be implemented.

3347.4 --> 3352.3: Like, hardwiring some filtering rules in a secure environment.

3353.3 --> 3360.0: Like, I'm sure it's doable in some way to some extent in some HSM, for instance.

3360.7 --> 3369.2: But, then you provide basically the technical means in order to see how compliance to regulation can be addressed.

3374.2 --> 3377.5: Unfortunately, many incidents happen by humans.

3379.1 --> 3387.2: And, we need to design some new operational model to reduce the number of points humans should be in the loop.

3401.3 --> 3404.3: I can share some insights from my work.

3405.4 --> 3409.5: Actually, I took a PhD for crypto key management offline.

3409.9 --> 3413.6: And, I actually worked for several crypto exchanges.

3414.1 --> 3420.9: Of course, HSM is one of the key technologies that we can use to safely store keys.

3421.2 --> 3425.3: At the same time, I was always facing some problems.

3426.3 --> 3432.4: Like, HSM, originally, it was designed for PKI industry, right?

3432.9 --> 3434.2: It's very initial.

3434.6 --> 3441.8: And, now, there are multiple products, like a code wallet or some other new generation's wallet as well.

3442.4 --> 3445.2: And, sometimes, we do have a question.

3445.6 --> 3450.8: For example, 143 or 2 is also fine.

3450.8 --> 3455.2: But, does that cover Bitcoin transaction models or whatever?

3456.6 --> 3467.1: And, when it comes to FIPS discussion, we really didn't have any FIPS certified product for HD wallet, for example.

3467.4 --> 3476.7: Because HD, Bitcoin's hierarchical wallet is not really covered by FIPS at all.

3476.7 --> 3482.7: So, by nature, it's really kind of a different world.

3484.8 --> 3488.7: Wallet address generation is not protected by FIPS.

3489.0 --> 3497.5: But, of course, signing processes or key management processes are protected by FIPS and certified by FIPS.

3497.8 --> 3499.0: That's totally understandable.

3499.0 --> 3509.6: So, we really need to think about what kind of a transaction message, Bitcoin transaction, Ethereum transaction, should be signed for the HSM.

3510.1 --> 3514.0: That's kind of our responsibility, not the HSM side responsibility.

3514.6 --> 3522.5: That was kind of a tricky situation, like scenarios that I was facing as a crypto exchanges.

3523.5 --> 3541.3: And, I don't know, for the entire key cycle management as well, key generation sometimes is also kind of not protected by crypto to assets type of algorithms.

3541.7 --> 3547.1: For example, like MPC wallet, is that supported by HSM, like current generation of HSM?

3548.5 --> 3558.5: That kind of algorithmic question is always kind of a problem when we think about using HSM as well.

3558.7 --> 3565.0: So, of course, we want to automate everything to secure our key by HSM.

3565.4 --> 3575.0: But, not always the HSM can become an available solution for the kind of operation.

3575.0 --> 3578.9: So, that was kind of nice to mention, I guess.

3579.9 --> 3586.8: Yeah, I completely agree with the previous commentator's discussion points.

3586.8 --> 3605.8: For example, in CCSS, we put in a requirement that the storage of key material must be in a container or an HSM that is FIPS-2 or FIPS-3.

3605.8 --> 3616.8: And we actually had community feedback, including Fireblocks, that said that FIPS doesn't even support their algorithms.

3617.5 --> 3621.6: So, we actually had to pull that requirement out of CCSS v9.

3622.4 --> 3631.8: So, HSM is great, but a lot of the technologies out there now on blockchain and crypto, sometimes the HSM can't actually support it.

3632.9 --> 3637.5: Or support the entire signing process and so forth.

3638.4 --> 3651.9: The other thing, too, is that the focus here on HSMs, it's great, but there's actually, of some of the exchanges that I have audited, and some of them are quite large global entities, they've implemented legacy systems.

3652.7 --> 3654.7: They don't use HSMs.

3655.1 --> 3656.4: They even encrypt key material and put it into a database and store it there.

3663.0 --> 3664.5: And that's for cold wallet as well.

3665.0 --> 3676.0: And they are not going to spend the money and take down production to put in an HSM when they're transacting in billions of dollars of crypto.

3676.7 --> 3685.2: So, probably something to look at is maybe infrastructure or architectures where HSM is not used.

3686.2 --> 3686.8: For cold wallet.

3688.6 --> 3691.8: And again, classic example, I've seen it so many times.

3692.3 --> 3694.4: Encrypted key material in a database.

3695.1 --> 3696.9: They pull the key material out.

3697.6 --> 3704.5: They might have a symmetric key stuck in KMS somewhere, AWS KMS, decrypt the key material.

3704.9 --> 3710.6: They sign it in general memory on a hardened server most of the time.

3711.0 --> 3714.3: And then they destroy the key material that they've decrypted.

3715.4 --> 3720.6: Some of those things I don't actually think have been addressed properly in the market.

3750.0 --> 3762.2: I think it goes into the direction of there are different nuances on offline key management slash cold storage.

3762.5 --> 3770.1: So, defining, describing those different nuances makes sense with the typical example.

3770.3 --> 3774.4: I mean, we can think about many ways to do it, but at least with the typical examples.

3775.3 --> 3776.7: It could be of interest.

3778.4 --> 3799.4: Because then with this effort of describing, then we can really try to list benefits, risk, and potentially at some point also additional mitigation that could be put in place in order to improve further.

3806.7 --> 3810.6: Have you started with the taxonomy work yet?

3812.3 --> 3820.4: So, I'm actually thinking, yeah, might be better to start with the taxonomy and then the lifecycle.

3823.4 --> 3838.0: The other thing that might be helpful, and again, I don't think anyone's done it yet, is helping these environments, these architectures that don't use HSMS, what additional controls can they put in place to protect it?

3838.0 --> 3854.8: The other thing too, I've seen it in PCI, the Security Standards Council for PCI, they've got some pretty strong standards around key injection facilities and putting keys into terminals and stuff.

3855.7 --> 3858.9: They've got some really good stuff about physical security as well.

3860.2 --> 3866.5: So, maybe you could even look at recommendations for physical security of key signing as well.

3866.5 --> 3868.8: There seems to be generally missing.

3873.5 --> 3873.9: Yeah, agreed.

3878.7 --> 3886.0: What I mentioned, I think, earlier, it's probably not only about signing, it's also about transaction validation.

3886.0 --> 3897.1: So, those processes and how to do it securely in an isolated environment, physical security, and guidelines also to be able to do it is probably missing.

3897.1 --> 3913.1: And at the same time, how to also reduce the manual-lash-human workload versus automation of the process itself, which makes sense.

3913.3 --> 3917.4: I mean, you are not going to sign manually every transaction, of course.

3919.3 --> 3923.4: So, yeah, all those aspects are interesting.

3931.6 --> 3943.2: Among the different architecture systems that are out there, yeah, definitely additional mitigations for those not using HSM.

3944.9 --> 3956.0: There are also considerations like you never know if a key has been leaked or not before something happens.

3957.1 --> 3967.4: So, there is also a notion of how to migrate your keys from new ones when you add new control to your system.

3968.0 --> 3970.3: So, this is also something that can be described.

3971.6 --> 3981.9: Because sometimes, yeah, maybe you are adding just, let's say, a physical access control to your data room where you are signing the key, a more robust one.

3981.9 --> 3989.5: But if anything happened before, still, you need a way to migrate the system.

3989.6 --> 3998.0: Otherwise, well, it's just about adding something to maybe a room where a window has been already opened.

3998.1 --> 4000.6: So, you need to do something more.

4000.6 --> 4020.7: So, those kind of guidelines also on how to, well, to level up your security and how to ensure that you are not dragging all the past weaknesses that may still be exploitable in a way.

4023.3 --> 4035.1: Also, if I may add, I've also noticed that some of the companies also do some, you know, like changing their passwords in that sense.

4035.2 --> 4040.8: Similar to rotating the keys on some time frame in that sense too.

4041.0 --> 4045.3: So, I've noticed that the practice has also been evolving around that as well.

4061.7 --> 4069.2: So, what I wanted to say was, like, well, as they're re-encrypting of the keys or, like, well, revocation of the keys, for example.

4069.4 --> 4071.7: Like, as you mentioned, it's a lifecycle discussion.

4071.7 --> 4080.5: It's kind of tricky in the crypto world because, like, once you generate a key, like, well, there is a wallet, like, well, for the entire time.

4080.9 --> 4086.8: So, it's kind of a rare scenario that we need to destroy the key, I guess.

4087.1 --> 4088.9: Like, well, unlike the PKI industry.

4089.2 --> 4098.6: Like, well, PKI industry, once the key is compromised, then, like, well, just the key is, like, revoked by the CRL or the other means.

4098.6 --> 4108.7: But, like, well, in reality, in the crypto industry, like, well, even though those kind of compromised addresses, compromised key wallet addresses,

4109.5 --> 4122.6: maybe exchanges need to hold, keep holding the key, even we know if the key is compromised for the sake of, like, I don't know, like, well, customer funds protection, whatever.

4123.1 --> 4133.9: But at the same time, like, well, in the future, like the PQC type of thing, like long-term crypto things, we need to think about, like, well, the migration at some point in the future.

4134.1 --> 4142.4: So, what I really don't know is, like, well, when to actually rotate the key of the wallet at the institutional level, for example.

4142.6 --> 4149.5: Like, well, we have a kind of huge wallet that have, like, keeping their, like, majority of the customer's fund.

4149.5 --> 4162.3: But when we need to, like, well, migrate, like, transfer those kind of massive funds to one wallet address to another, like, well, is that transfer process itself is secure?

4162.6 --> 4167.0: Are there any, like, kind of adversaries involved, like, even internal threat?

4167.0 --> 4175.3: Or is the system secure, really? Or is the algorithm not, like, functioning funny?

4175.7 --> 4181.0: Or those kind of difficult perspectives of question arise, like, everywhere.

4181.5 --> 4185.8: And once we make any, like, small mistakes, then, like, everything is ruined.

4185.9 --> 4190.0: That's kind of a, like, scary part of the crypto exchange, I guess.

4190.5 --> 4192.4: Yeah, that's a very good point.

4192.4 --> 4220.7: If we think about the Bybit hack, for instance, imagine that if it would have happened during major migration process, like, you are able to force using a rogue smart contract, for instance, during a major migration process for whatever that rely on still on a smart contract.

4220.7 --> 4222.6: It would be a nightmare.

4223.3 --> 4228.8: So, indeed, during the migration process, how to ensure that everything remains secure?

4228.9 --> 4235.9: How to ensure that you maintain your initial security requirements?

4236.3 --> 4240.2: Yeah, that's initial or additional ones if you are adding additional ones.

4240.5 --> 4246.0: But, yeah, that's also a very good and relevant point.

4256.1 --> 4258.2: I also want to add some other things.

4258.4 --> 4270.3: Like, well, actually, like, when the code operation, like, well, at the organizational level, like, well, the human factors are also quite important.

4270.3 --> 4277.2: For example, like, well, think about one exchange, one company, like, well, any company is fine.

4277.4 --> 4285.0: Like, well, five C-level people are working, and maybe three out of five signatures is required.

4285.0 --> 4289.7: But what if there is a kind of split in the executive group?

4290.0 --> 4295.5: Like, well, what other company trying to acquire a company in a hostile way?

4296.1 --> 4304.0: Do, like, well, those, like, legacy C-level people give access to the other keys?

4304.2 --> 4309.1: Or what if, like, well, those old executives decline to, like, transfer the key?

4309.1 --> 4313.3: That's kind of a, like, kind of a tricky question.

4313.5 --> 4316.0: But, actually, that's really realistic.

4316.4 --> 4318.1: But at the same time, important question.

4319.5 --> 4329.2: But that should fall under what would be, well, it depends on how professional the organization is and whether they're publicly traded or how big they are.

4329.6 --> 4334.9: But it should fall under, like, governance provisions, generally speaking.

4334.9 --> 4350.9: So if you are an executive at one of these exchanges, again, depending on the professionalism of the organization, there are, you know, it's not a code of conduct, but there are governance rules.

4351.2 --> 4354.8: And if you violate them, well, there's supposed to be consequences.

4355.1 --> 4363.1: So I think if it's an M&A situation, that will be baked into the transfer of power of who gets to do what.

4364.0 --> 4366.6: So, to me, that's more of a governance topic.

4367.5 --> 4372.1: But, again, if you want, if people go rogue, it's humans going rogue.

4372.2 --> 4373.5: So I don't know what you can do about that.

4374.0 --> 4375.5: Yeah, yeah, definitely.

4375.5 --> 4382.6: In particular, let's say it's not a very huge company.

4382.9 --> 4384.4: Governance might be okay.

4384.7 --> 4394.5: But still, if they are not relying, for instance, on, let's say, keys have been stored in a way that they may have been able to see the private key.

4395.5 --> 4397.6: How to make this transfer?

4398.4 --> 4403.8: Do you need to launch a full rotation of the approval keys of the C-suite?

4403.8 --> 4407.4: Well, there are questions that are definitely valuable there.

4409.8 --> 4412.8: The Canadian exchange, that guy died, right?

4412.9 --> 4416.5: And then he was, like, the only one that had, yeah, that was very bad governance.

4418.1 --> 4418.3: Huh?

4419.3 --> 4420.8: You remember the Canadian exchange?

4421.3 --> 4421.9: What was it called?

4422.8 --> 4423.3: Quadrica.

4425.9 --> 4435.2: So some of my audit experience, I provide advisories to regulators around the world, some of my clients.

4435.8 --> 4439.4: And it's based on what I've discovered while I'm auditing exchanges.

4439.9 --> 4445.4: And I've got these 15 red flags that I tell the regulators to watch out for.

4445.7 --> 4449.1: And they don't even have to understand the technical aspects of blockchain.

4449.1 --> 4456.0: And one of them is if the founders of the organisation still have access to key material.

4456.4 --> 4459.5: And this might be a multi-billion dollar exchange.

4460.1 --> 4464.7: And you will see sometimes they'll have the founders controlling the cold wallet key material.

4465.2 --> 4471.7: And that the security operations teams and so forth are too scared to actually ask the founders about what they're doing with it.

4472.6 --> 4475.1: And that's another Quadrica thing as well.

4475.1 --> 4483.7: So red flag for regulators is if the founders, even though they're an enormously large corporation, still have access to key material.

4484.5 --> 4487.6: So that's pretty much a big red flag.

4489.0 --> 4500.3: The other thing too about physical security is some environments I've been in, they have vaults, you know, rooms.

4500.3 --> 4504.8: Secure rooms in their offices where they do key ceremonies.

4505.2 --> 4510.5: And they have a lot of security controls, physical security controls and stuff.

4510.8 --> 4519.4: But one of them I actually asked, well, you know, in regards to service provider management, what do you actually do?

4519.6 --> 4521.9: How do you gain assurance if you need to swap out?

4522.0 --> 4523.1: Because they're not using HSMs.

4524.5 --> 4530.6: They've actually got servers, physical machines in these vaults.

4530.7 --> 4536.4: And I said, well, what happens when the machine breaks and you actually have to replace that computer?

4537.2 --> 4539.0: How do you know it hasn't been compromised?

4539.3 --> 4546.6: You know, Edward Snowden with the NSA about how they used to intercept the devices and put chips in them and stuff.

4546.8 --> 4548.1: And they didn't have a clue.

4549.2 --> 4551.9: So, you know, that comes back to physical security as well.

4551.9 --> 4553.6: And service provider management.

4564.8 --> 4566.0: Any other thoughts?

4571.4 --> 4574.7: So it sounds like we have something we should work on.

4576.0 --> 4576.6: Yeah.

4577.6 --> 4581.2: I hope we'll have contributors.

4591.6 --> 4592.4: Again.

4594.5 --> 4606.9: I think describing, well, kind of taxonomy, describing different concepts and offline key management, different kind of uses.

4607.4 --> 4618.7: And from there, we can start to describe pros and cons and, well, potential additional controls, processes, governance, etc.

4619.7 --> 4625.2: But starting with describing different cases.

4626.2 --> 4639.7: I think it's needed because we don't have all the same understanding of what is called storage versus offline and the different possibilities.

4644.3 --> 4656.8: Maybe we'll start by addressing those without HSM because there is quite a few, well, a few items to be discussed there.

4656.9 --> 4661.0: But I see also value at some point to do it with HSM as well.

4661.0 --> 4670.4: I mean, it's not because you are using an HSM that you should not have proper processes in terms of governance and so on.

4671.1 --> 4676.2: And also ways to manage backup recovery and so on.

4676.7 --> 4676.8: Yeah.

4680.4 --> 4693.0: One of my, actually, like, my paper, like, two years ago, like, well, actually listed several different types of wallets, like software wallet, like paper wallet, whatever, like, OSHA wallet.

4694.1 --> 4695.9: That's actually publicly available.

4697.2 --> 4700.5: Put the URL here if you can see.

4700.5 --> 4718.0: So, like, the type of, like, wallet, like, well, written wallet or knowledge type of wallet, like, well, there are, like, bunch of different types of wallet, like, are used even, like, when they're personal, like, individual level or, like, enterprise, like, institutional level as well.

4718.3 --> 4722.0: And those have, like, different type of, like, risk profiles as well.

4722.0 --> 4738.2: And, for example, like, for backup purposes, even, like, institutional level, like, multi-billion dollar wallet, they do have, like, 24 unique words, which may be, like, instantly, like, memorized by some people.

4738.4 --> 4742.0: Like, is that acceptable by the institution operation or not?

4742.2 --> 4744.8: That's kind of tricky, like, kind of question.

4744.8 --> 4763.5: And actually, like, in this paper, I tried to, like, suggest, like, what would be kind of an extreme way of, like, keeping the funds in a cold manner, even without, like, kind of a reproducible, like, known kind of proprietary method.

4763.8 --> 4772.9: And that actually uses, like, well, their, like, secure, like, secure room, security room, if I say.

4772.9 --> 4788.9: So, that's kind of a way, one example, like, it's just kind of a one example of, like, keeping the wallet in an offline manner, but, like, well, that may be kind of a good, like, information to share here.

4832.8 --> 4832.8: Thank you.

4838.1 --> 4857.1: I think we need to consider how to manage that information and how to sign transactions without error.

4860.5 --> 4868.3: When this issue comes up, everyone starts talking about third-party management.

4869.3 --> 4876.1: However, I don't believe it's solely an issue on third-party management.

4877.1 --> 4890.3: Even within BASP's own wallet system, OSS JavaScript module could be compromised, and all the transaction addresses.

4890.3 --> 4898.3: I heard about the HSM whitelist feature earlier.

4899.1 --> 4908.8: I think that function could potentially be, I think that function can be used.

4908.8 --> 4932.2: Beyond just managing addresses, it would be beneficial to explore ways to ensure the correctness of transaction content to the entire process, from creating the transaction to signing it.

4941.9 --> 4943.3: Yeah, absolutely.

4943.9 --> 4946.2: It's not just about the key itself and signing.

4946.7 --> 4948.3: It's about the whole process, yeah.

4949.1 --> 4952.1: We should try to also to allow this.

4958.5 --> 4959.1: Okay.

4959.4 --> 4960.2: Chloe, please.

4964.7 --> 4970.9: I've just been reflecting about your questions on what beginners should prioritize in this space.

4971.9 --> 4992.9: And on the issue of taxonomy and aligning jurisdictions on a common language, unfortunately, even when standards organically emerge in global policy discourse in this space,

4992.9 --> 5007.2: what I've seen over a number of jurisdictions is that you will always have some policymakers that still prefer to invent their own language and just do not want to adopt the dominant taxonomy,

5008.7 --> 5027.9: either because they want it to fit in with their already bifurcated taxonomy through their other markets, or because of ego that it makes them feel like they're doing rocket science by creating their own terms and definitions for things.

5027.9 --> 5047.5: And it does create annoyance for the market and for other policymakers and regulators in other jurisdictions trying to understand where equivalences exist and trying to streamline compliance across borders is something that we know is a bugbear for market participants.

5049.2 --> 5065.5: But if I put on my former regulator hat and I look at that problem, I would say, yeah, I buy the argument that we can generate some incremental efficiency gains if we convince everyone to align on a global taxonomy.

5065.5 --> 5087.4: But I'm not sure if I care about devoting resources to those incremental gains as much as I care about preventing catastrophic losses through improving some cybersecurity gaps to prevent a hack or a loss or, you know, preventing leaks of sensitive personal information that risks people's physical security and things of that nature.

5087.4 --> 5099.6: So my two cents on this question is really just there's probably lots of different things that Begin could do on this.

5099.6 --> 5129.0: But my personal view is I think it's probably net-net a better path if we focus taxonomy efforts less on just trying to tidy up and neaten up regimes across borders, and instead think about some of those black swan risks that might be

5129.8 --> 5132.5: more serious when they do arise.

5132.8 --> 5136.9: So I just wanted to throw in my two cents based on wh

at I've observed.

5136.9 --> 5141.9: But I do really like some of these suggestions.

5142.8 --> 5148.0: I think that there's no single right answer about the direction to take.

5148.0 --> 5163.5: And it probably becomes really an issue of Begin's specific strengths and focusing on our strengths and the resources that we have at hand, including what partners we have available who want to collaborate with us on the work.

5163.5 --> 5171.7: Because I think that's something that is a real game changer for Begin when it comes to influencing standards and policy discourse as well.

5171.8 --> 5175.0: So just a little hot take from me.

5175.1 --> 5175.5: Thank you.

5175.5 --> 5177.0: Thanks a lot.

5177.6 --> 5178.8: It makes a lot of sense.

5179.2 --> 5199.5: And when we will discuss potential use cases, typical architecture that we can comment on, definitely we should look at those that are not exotic and used by an exchange managing, I don't know, two crypto assets a year to be a bit extreme.

5199.8 --> 5203.4: But really those that may have an impact in the industry.

5206.3 --> 5222.9: So to that point, I think having a subset of definitions from this group actually is important if this group wants to play on the global stage.

5223.3 --> 5226.8: Because it's not necessarily about every jurisdiction accepting it.

5226.8 --> 5236.8: It is putting a line out there that this is a standards group that is going to take very specific terms.

5236.9 --> 5241.7: And we don't even need to have that many, really, when talking about this particular subcategory.

5242.4 --> 5243.8: And we could borrow from others.

5244.0 --> 5250.0: But then it is to align with other groups like ISO, to align with other standards bodies like IEEE.

5250.4 --> 5251.7: And there's plenty of others.

5251.9 --> 5254.2: And we've got 500 definitions as well.

5254.3 --> 5255.5: I don't know how many of them align.

5255.5 --> 5264.1: But the point being is that work is important alongside the use cases.

5264.6 --> 5273.3: And then ultimately I think what you're talking about, drilling deep down into what are absolute catastrophic scenarios that need to be dealt with.

5273.6 --> 5275.1: I don't know that they're mutually exclusive.

5276.2 --> 5279.9: I would hope that this group is not going to spend an entire year on taxonomy.

5280.0 --> 5281.8: Because reality is there's a lot out there.

5282.2 --> 5283.7: Some of it's actually about aligning.

5283.7 --> 5286.4: And this is one other thing that we did.

5288.1 --> 5293.7: MECA versus the CFTC taxonomy and definitions that got approved last year.

5293.9 --> 5295.4: And we were the co-chairs of that.

5295.9 --> 5300.7: That was the first time a regulatory body actually approved a set of definitions and digital assets.

5301.0 --> 5303.7: We then compared and benchmarked what MECA did.

5304.3 --> 5307.5: And reality is there are terms that are absolutely aligned.

5307.6 --> 5310.9: And then there were terms that were somewhat equivalent.

5310.9 --> 5315.2: And then there was another set of terms that just are completely divergent.

5315.3 --> 5318.2: And we had to figure out how we're going to manage that.

5318.4 --> 5325.6: Because in Europe versus U.S. there were very different terminology for very similar things.

5325.8 --> 5331.6: And so the key is to have that body of work so we can do the analysis as well and call it out.

5332.1 --> 5333.6: So I hear you.

5333.9 --> 5338.5: But I do still think that a subset of the taxonomy does need to come from this group.

5339.8 --> 5341.7: Especially the more technical stuff.

5342.2 --> 5346.8: I was going to say that it's on the technical side.

5349.1 --> 5356.8: Anyway, it's needed to be able to organize, structure by categories the different use cases that we are describing.

5357.2 --> 5361.9: But it's not necessarily spending time trying to define something which would be universal.

5362.7 --> 5365.9: It's more being sure that we define properly what we are talking about.

5370.5 --> 5371.7: Seconded on both fronts.

5371.9 --> 5381.0: I know I've argued over the differences between digital, virtual, and cryptocurrency so many times.

5381.5 --> 5385.9: And I was completely horrified when the FATF came up with a virtual asset service provider.

5386.6 --> 5389.0: And that's what we had to agree to in 2019.

5389.3 --> 5391.5: And I was like, okay, I hate everything.

5392.4 --> 5393.5: But fine, fine, fine.

5394.1 --> 5397.9: So I feel like there are times where I'm like definitions I don't care at all.

5397.9 --> 5400.8: And then other times where I'm like they completely matter.

5401.5 --> 5405.8: Which tends to be around things like jurisdiction and legal application and litigation.

5407.4 --> 5414.7: So from that perspective, I totally agree that while I know that level of harmony will continue to be frustrating.

5414.9 --> 5421.2: And the tensions that exist between different frameworks across jurisdictions.

5421.7 --> 5424.9: Even different regulators like the SEC had its preferred definitions.

5425.0 --> 5429.1: And FinCEN had our own for different reasons.

5430.4 --> 5433.1: For example, FinCEN used virtual currency.

5433.7 --> 5436.7: And it wasn't defined as something digital in nature.

5437.0 --> 5439.0: Virtual just meant not legal tender.

5439.5 --> 5442.2: So it would cover things like beads and shells.

5442.6 --> 5445.3: And 3D printed figurines of Sandra Rowe.

5445.4 --> 5447.5: Which is my plan for my future currency.

5447.8 --> 5450.1: And the co-op that I will eventually create.

5450.2 --> 5451.5: And my plan for world domination.

5452.8 --> 5457.0: Because FinCEN wanted to make sure that it captured forms of money.

5457.3 --> 5459.1: Whether they were state backed or not.

5459.3 --> 5461.2: We didn't care if it was physical or digital.

5462.1 --> 5465.3: But that's not terribly helpful to a crypto developer.

5465.6 --> 5466.6: That's not a useful term.

5467.6 --> 5472.0: But that level of confusion was a really manifest issue.

5472.3 --> 5478.5: And was certainly not helpful to people that are trying to support and defend the cyber security of the ecosystem.

5478.5 --> 5482.2: So I agree that I think we'll need to come up with a version of taxonomy.

5484.1 --> 5485.3: For those issues.

5485.5 --> 5489.7: So that as we define the standards and controls.

5490.8 --> 5492.9: It's clear at least what we're talking about.

5493.3 --> 5496.3: And then we'll do our best to try to harmonize that with what does exist.

5496.5 --> 5499.2: But I feel both tensions on that.

5504.0 --> 5504.6: Thank you.

5505.9 --> 5508.5: You wanted to have the last words, right?

5508.9 --> 5509.5: Of the session.

5509.8 --> 5510.8: Because the session is over.

5513.0 --> 5513.7: I'm kidding.

5514.3 --> 5515.4: Thank you everyone.

5516.5 --> 5520.2: I think we have 10 minutes break or something like this before the next session.

5521.1 --> 5521.5: Thank you.

5526.7 --> 5529.3: We have 10 minutes break from now.

5529.5 --> 5532.7: And the next session will start at 3.30pm.

5532.7 --> 5536.1: And this room is...

5536.1 --> 5537.0: Which session?

5541.4 --> 5543.6: This room is for audit.

5543.8 --> 5547.3: The other room is for stablecoin implementation guideline.

5548.5 --> 5552.1: But both sessions should be interesting.

5552.9 --> 5561.1: But at the other session I will demonstrate how my st

ablecoin payment was difficult.

5562.7 --> 5564.3: For the registration fee.

5567.7 --> 5569.6: So let's continue our discussion.

5570.1 --> 5570.5: Thank you.

5601.5 --> 5604.3: Thank you.

5646.9 --> 5649.7: Thank you.

5655.2 --> 5657.9: Thank you.

5698.0 --> 5699.4: Thank you.